

Block 00b — fourth to sixth review dispositions and pre-final hardening receipt

Status at source generation: all findings from the fourth Copilot review have dispositions, and an owner-directed hardening pass over EIP-712, legacy storage and reset scratch is implemented and locally qualified. **Final-head hosted CI is pending.** Block 00b is not accepted, merged or released. No Copilot verdict has been clean; every review so far returned **Changes recommended**.

Identity and boundary

- PR: [#856](#), base release/715-stack-00-audit-base at 9cb72384fd14b2a688a70d17711a7923941d2290.
- Reviewed head: b1c31a33e51813584b70e77604d978e8811e4e21, [exact-head CI 35981212894](#) green.
- Copilot reviews delivered: 5297484301 (d2b1cdfb1), 5298915862 (71ce20c7d), 5300329714 (7f63e7246), 5302566773 (b1c31a33e). The third review's five findings were dispositioned on-thread in b1c31a33e.
- This receipt's code commit is the child of b1c31a33e. Its SHA and final CI run are recorded on the PR.

Fourth review (5302566773) dispositions

Comment	Disposition
4092078282, 4092078311, 4092078354	Declined with evidence. add_custom_command(TARGET ... POST_BUILD) is valid on a custom target in CMake 3.7.2; only PRE_LINK is not. The exact-head jobs configured and produced the named JUnit files.
4092078403	Declined with evidence; the decline stands for 00b. kkemu_init() never calls timer_init(), so the dylib installs no concurrent SIGALRM. The same investigation found a separate emulator-only defect: on POSIX, nothing advances remaining_delay while firmware blocks in delay_ms(). A fix is written but deferred by owner decision to #860 . Once animations actually run, the pinned python-keepkey bitcoin-only test races the home animation (1 failure locally), so the fix must land together with a pyk test fix and pin bump. Device firmware is unaffected.
4092078446	Declined with evidence. fsm_msgThorchainMsgAck rejects any explicit non-rune denom before this confirmation, so no non-RUNE amount reaches the RUNE-labelled screen.

Owner-directed hardening (not from Copilot)

Area	Defect	Fix and forbidden result	Regression
EIP-712 hex	encodeBytes/encodeBytesN walked hex in two-character steps with strtol. An odd-length string advanced past its terminator, and non-hex silently became 0.	Whole-string validation (0x, even length, hex digits, exact bytesN length) before any read or output. Forbidden: reading past NUL, or publishing output for malformed input.	MalformedHexNeverPublishesEncodedOutput, ByteEncodingMatchesIndependentHashAndRightPadding
EIP-712 bytesN width	Width parsed through uint8_t: bytes288 wrapped to 32 and entered the typehash. bytes0/bytes01 were accepted.	One strict parser (1..32, no leading zero) for both typehash and encoder. Array suffixes still reach the existing BYTESN_ARRAY_ERROR.	BytesNTypeWidthIsStrictInTypeHashAndEncoder
EIP-712 JSON shape	Values of the wrong JSON shape reached strlen/strtoll through tiny-json's overlaid child pointer. Fixed-size arrays were not length-checked. intN width and range were unchecked.	Shape, declared array length and integer width/range are checked before any screen or hash update.	MismatchedJsonShapesAndFixedArraysAreRejectedBeforeHashing, IntegerWidthAndValueMustMatchBeforeHashing, NarrowIntegerBoundaryMatchesIndependentEncoding, DecimalSignPaddingMatchesParsedValue, MissingFieldRefusedWithoutDereferenceOrHasMutation

Area	Defect	Fix and forbidden result	Regression
EIP-712 consent order	address, address[], bytes and bytesN showed the value to the user before the encoder validated it. The user could approve a value that was then rejected.	Encode first; address[] is validated in full before the first screen. Forbidden: any screen for a value that will be refused.	MalformedBytesAndAddressesRejectedBeforeAnyValueScreen (failed 6/6 before the fix)
Reset scratch	The exit path wiped display scratch through pointer aliases with sizeof(alias), clearing only a pointer-sized prefix of mnemonic display buffers. setup_abort did not clear shared scratch.	Wipe the backing arrays by their real size on every exit and on abort.	ReviewHandlers.Reset*ClearsScratch*, SetupCeremony.AbortScrubsEveryByteOfSharedMnemonicDisplayScratch
Legacy storage v1/v2	17-byte legacy language copied into a 16-byte field (no NUL). v2 cache read past the length passed to the reader.	Bound the copy by the destination with a NUL, pass the real record length, and validate the cache extent before mutating the destination.	Storage.LegacyLanguageIsBoundedAndTerminated, Storage.TruncatedLegacyCacheDoesNotMutateDestination

All new cases are in BASE_REQUIRED_CASES, so the report gate fails if any is missing.

Executed checks and limits

All results below are for the exact committed tree, with python-keepkey at its unchanged pin 98c717ff. They were run locally in CI's images; hosted CI at the new head is still required.

Gate	Full	Bitcoin-only
Native unit (firmware / crypto / board / other)	370 / 19 / 20 / zcash 59+1, emulator 4, 0 failures	104 / 19 / 20, 0 failures
python-keepkey host on rebuilt emulator	559 passed, 272 skipped	334 passed, 497 skipped
ARM cross-compile, pinned kktech/firmware image	clean, no warnings; text 560,384 B	clean; text 357,408 B
SRAM budget gate	PASS, reserve 21,256 B	PASS, reserve 31,368 B
clang-format 20.1.8 on changed C files	clean	clean

Eip712.MalformedBytesAndAddressesRejectedBeforeAnyValueScreen was run against the unfixed code first and failed all six cases (value screen shown, USER_CANCELLED returned), then passed after the fix. EIP-712 is excluded from bitcoin-only, which is why its firmware count is lower.

Not re-run locally: the macOS dylib lifecycle job. Its sources are unchanged from b1c31a33e.

Hosted-CI correction

CI 36083577235 at fd4a2d5ce failed static analysis: cppcheck knownConditionTrueFalse at eip712.c:605. The old walkVals == 0 branch became unreachable once the new shape check refused a missing value before any screen. The zero-warning gate then skipped the whole build graph, so that run qualifies nothing. The follow-up drops the dead condition and keeps the block scope unchanged, to avoid re-indenting about 300 lines. Behaviour is unchanged. cppcheck was not re-run locally after the last source edits, and Docker was unavailable for the follow-up, so **hosted CI at the follow-up head is the qualification for this receipt.**

Fifth review (5313465732) on c4d10686f

Verdict **Needs a closer look** (Lite). It had one finding and listed all five fourth-review findings as resolved.

Comment	Disposition
4101 1656 18	Fixed. release_missing_capabilities() turned any skipped test's free-text reason into a capability waiver, so an unrelated skip naming evm-max-amount-review or osmosis-wire-guards removed those required controls from the gate. Every declared or env-supplied waiver must now be on the single ledger: the integration job's KK_RELEASE_MISSING_CAPABILITIES line in the checked-out ci.yml, which must occur exactly once. Anything else fails the report.

Comment	Disposition
Same-class audit	Fixed. Required controls were matched with <code>name.endswith(required)</code> , so XEip712. Case satisfied Eip712. Case. Matching now requires the exact name or a <code>.</code> -delimited suffix (Python classnames may carry a module path).

Evidence:

- `scripts/test_generate_test_report.py` (6 cases) runs in the report job before the PDF is built.
- The old code accepts an unapproved waiver (control).
- On the real artifacts of green run 36093027358, the new code's waivers are 13 (full) and 12 (bitcoin-only), all on the ledger.
- The complete `validate_cases` gate passes under both old and new code on the real 1,395-case full-variant input. So the tightening rejects only the bad inputs.

Sixth review (5314077647) on 5e2e3d16b

Verdict **Needs a closer look** (Lite). It had one finding and listed the fifth-review finding as resolved.

Comment	Disposition
410 163 752 2	Fixed. 00b's delete resync rebuilt <code>coded_word</code> from the current <code>cipher</code> , on the stated assumption that the session cipher is fixed. That assumption is false: <code>next_character()</code> re-scrambles the cipher before every character. After a backspace, <code>coded_word</code> therefore held letters the user never typed. It feeds the "typing the seed without the cipher" heuristic, which could abort a valid recovery. Now <code>coded_word</code> keeps only the characters actually typed and is truncated on delete. When a delete steps back over a space into a finished word, whose typed characters were discarded at the boundary, the coded prefix is marked unknown and the heuristic is skipped for that word. It is never guessed. The flag clears at every word boundary, at mnemonic start and on reset.
Same-class audit	The only other use of <code>cipher</code> decodes the character that was just typed, under the mapping that was just displayed, which is correct. The DebugLink read is test-only. The per-word BIP39 validation already reads <code>decoded_word</code> , which is resynced from the mnemonic.

Regression: `Recovery.DeleteKeepsTypedCipherCharactersNotTheCurrentMapping`, via the firmware-unit probe. It uses an identity cipher, under which the old reconstruction yields `ab` instead of the typed `qw`. It also covers crossing a word boundary, and an unknown prefix that persists until the word is emptied. Local Docker was unavailable and local `cppcheck` 2.20 failed its control (it did not reproduce CI's earlier finding), so **hosted CI is the qualification for this change**.

Not claimed: physical OLED review of the new EIP-712 refusal paths, or Windows runtime. A resolved thread is a disposition, not a clean review. Any later source change makes these results historical.